

FARI

Example Investigation Report

USB APID 0x06 Undersized Telecommand

Release source: 03-usb-apid-underflow-report.md

FARI v1.3.0 | 2026-08-23

INCONCLUSIVE

Qualitative executive conclusion from the example report

This is the versioned release edition of the FARI documentation bundle. Canonical working sources for this release are stored under the same version folder.

Document Control

- **Assessment ID:** ASM-FARI-2026-003
- **Investigation ID:** INV-USB-002
- **Report version:** 0.3
- **Report maturity:** Provisional
- **Report date:** 2026-06-08
- **Source material:** cases/03_USB.md (../cases/03_USB.md) and cases/usb_tc_apid_underflow_cmd.png (../cases/usb_tc_apid_underflow_cmd.png)
- **Evidence producer:** Auditor; identity not supplied
- **Report author:** FARI Report Author
- **Mission owner / risk authority:** Not supplied
- **Framework profile:** No external framework profile was required for this report.

1. FARI Result Card

Field	Result
Conclusion	Inconclusive
Confidence	Low
Required Action	Extend Investigation, then Retest
Priority	Immediate before treating the USB command path as resilient to malformed packets
Scope Boundary	One malformed APID 0x06 telecommand constructed and sent through the supplied USB lab procedure; handler execution, memory corruption, persistent command loss, RF reachability, and on-orbit behavior excluded

Rationale: The supplied screenshot demonstrates construction and transmission of an undersized APID 0x06 packet and no received bytes before timeout. The source excerpt supports a credible unsigned-underflow hypothesis. The supplied material does not demonstrate that the target handler executed, that an unsafe copy occurred, or that the target stopped accepting subsequent commands.

2. Executive Decision Summary

The source material identifies a credible unsafe-length calculation in a BROADCAST_MSG handler and demonstrates that a one-byte APID 0x06 packet can be sent through the USB lab procedure. This is enough to require an immediate, instrumented retest and defensive length validation.

It is not enough to conclude that denial of service, memory corruption, or code execution occurred. A timeout has multiple possible explanations, including no defined response, framing rejection, handler rejection, transport behavior, or target failure.

Decision required: Do not claim resilience or confirmed exploitation. Instrument the handler, prove packet acceptance and post-test command behavior, then resolve the claim.

3. Frame

Mission Context Added by the Report Author

The supplied material does not identify the mission architecture. This report uses the explicit assumption that safe telecommand parsing and continued command handling support spacecraft commandability and recovery. Mission-owner confirmation is required.

Scope

Item	FARI Record
Primary asset	AST-USB-TC-002 USB-exposed telecommand parser
Related asset	AST-FSW-BCAST-001 APID 0x06 broadcast-message handler
Segment	Space-segment representative lab interface and simulated link
Access basis	Private, as stated by evidence producer
Environment	Static/offline source excerpt and dynamic USB lab execution
Claim	CLM-USB-002: Undersized broadcast telecommands are rejected without unsafe memory access or loss of command handling
Explicit exclusions	Actual RF delivery, on-orbit behavior, authentication path, exploitability beyond the supplied packet, and mission-level consequence

Authorization

No authorization reference, stop condition, test date, target revision, or evidence-handling record was supplied.

4. Acquire: Source-Material Intake Review

Evidence Index

Evidence ID	Source	Directly Supported Statement
EVD-USB-003-001	Supplied source excerpt	The documented handler calculation derives <code>payload_total</code> , subtracts two, and passes the result to <code>memcpy</code>
EVD-USB-003-002	<code>usb_tc_apid_underflow_cmd.png</code>	A decoded TC packet for APID <code>0x006</code> with length field <code>0</code> , data-field size <code>1</code> , and data <code>00</code> was sent using the USB command
EVD-USB-003-003	<code>usb_tc_apid_underflow_cmd.png</code>	The tool reported no bytes received before timeout

Evidence-Backed Facts

- The supplied source excerpt contains the sequence `payload_total = header.length + 1`, `msg_len = payload_total - 2`, and `memcpy(buffer_msg, data + 2, msg_len)`.
- The screenshot shows the command targeting `/dev/cu.usbmodemfsat3` with `broadcast --payload-hex 00`.
- The decoded packet is a TC for APID `0x006` (`BROADCAST_MSG`), length field `0`, data-field size `1`, captured bytes `7`, and data `00`.
- The screenshot reports that no bytes were received before timeout.

Evidence-Producer Assertions

- The arithmetic uses an unsigned length and underflows when the declared payload is shorter than two bytes.
- The resulting copy can cause memory corruption.
- The current lab build may stop accepting commands until reset or USB re-enumeration.
- The weakness could become denial of service or code execution over RF.

Report-Author Inferences

- If `msg_len` is unsigned and the supplied code executes for the demonstrated packet, subtracting two from a value of one would produce a very large copy length.
- The screenshot supports delivery by the sending tool, but not target-side handler acceptance.
- The observed timeout is compatible with target failure, rejection, absent response behavior, or transport/tool behavior and therefore cannot establish denial of service by itself.

Contradictions and Quality Issues

ID	Issue	Reporting Decision
GAP-USB-013	The supplied code excerpt for the sender uses a TCP connection, while the reproduction screenshot uses a serial-device option	Require the exact executed tool revision and transport path
GAP-USB-014	The text asserts persistent command loss, but no baseline, post-test command, reset, or recovery evidence is supplied	Treat denial of service as unconfirmed
GAP-USB-015	The finding states that the library has DoS in APID 0x06, which is broader than the evidence	Exclude the generic conclusion and preserve the investigation as Inconclusive
GAP-USB-016	The source excerpt has no file path, revision, type definition, or build context	Treat root-cause and exploitability analysis as provisional

Sufficiency Decision

Question	Decision	Rationale
Technical condition	Partial	Credible unsafe arithmetic is shown, but execution and memory effect are not demonstrated
External / operational reachability	Partial	USB-side transmission is evidenced; target acceptance, RF delivery, and authentication are unknown
Mission consequence	Insufficient	No loss of command handling, recovery behavior, or mission effect is evidenced

5. Relate: Candidate Finding and Mission Context

FND-USB-002: Undersized Broadcast Message May Produce Unsafe Copy Length

- **State:** Candidate
- **Condition:** The supplied handler excerpt derives a message length by subtracting two from a payload total without an evidenced minimum-length check.
- **Observed effect:** A one-byte APID 0x06 telecommand was sent; no response bytes were received before timeout.
- **Unobserved but credible effect:** Unsafe memory access, handler failure, or command-path interruption if the packet reaches and executes the shown code.

- **Preconditions:** The demonstrated packet reaches the handler; the supplied arithmetic and types match the tested build; no upstream validation rejects the packet.
- **Technical confidence:** Medium for the code-pattern concern; low for target-side execution and effect.

Framework Mappings

Mapping	State	Rationale
CWE-191 Integer Underflow	Candidate	The source excerpt suggests subtraction below the minimum valid payload size; types and execution are not confirmed

Qualitative Mission Context

Given access to a command-delivery path and an undersized APID 0x06 telecommand, the handler may derive an unsafe copy length and interrupt command handling, potentially harming commandability or recovery.

This scenario is credible but not demonstrated. FARI therefore records an actionable **Inconclusive** result instead of a vulnerability score or a confirmed mission-level denial of service.

6. Inform

Required Instrumented Retest

1. Record the exact sender version, target revision, transport path, and packet bytes.
2. Capture a successful baseline command and response before the malformed packet.
3. Instrument handler entry, parsed lengths, copy length, rejection path, process state, watchdog activity, and memory-safety diagnostics.
4. Send the malformed packet once under defined stop conditions.
5. Send a known-good command immediately after the test and record the result.
6. Record recovery, reset, and USB re-enumeration behavior.
7. Repeat after adding a minimum payload-length check.

Required Remediation

- Reject payloads shorter than the handler's minimum required fields before subtraction or pointer arithmetic.
- Use checked arithmetic and size-bounded copies.
- Add regression tests for zero-, one-, and boundary-length payloads.
- Record malformed-command counters and explicit rejection telemetry.

Acceptance Criteria

- All undersized APID 0x06 packets are rejected before copy operations.

- No sanitizer, fault, reset, watchdog, or abnormal process event occurs.
- A known-good command succeeds immediately after each malformed input.
- The patched behavior is demonstrated in the representative command path.

Evidence Gaps and Follow-Up Requests

Gap ID	Requested Evidence	Why It Matters
GAP-USB-017	Handler source file, types, revision, and build flags	Confirm the arithmetic and applicability
GAP-USB-018	Exact executed sender and USB framing implementation	Resolve the transport contradiction
GAP-USB-019	Target logs, debugger/sanitizer output, and post-test command	Resolve handler execution and denial-of-service claim
GAP-USB-020	RF-path and command-authentication evidence	Evaluate operational reachability
GAP-USB-021	Mission recovery requirements and unacceptable outcomes	Evaluate mission consequence

Assurance Statement

CLM-USB-002 is **Inconclusive** with low confidence. The supplied material demonstrates malformed-packet construction and USB-side transmission and supports a credible unsafe-length hypothesis. It does not demonstrate target-side memory corruption, persistent command loss, RF reachability, or mission consequence.

7. Coverage

Area	Coverage	Result
Malformed packet construction	Tested and evidenced	APID 0x06, one-byte data field
USB-side transmission	Tested and evidenced	Sender reported packet sent
Target handler entry and unsafe copy	Not evidenced	Requires instrumentation
Post-test command handling and recovery	Not assessed	Requires baseline and recovery commands
RF delivery and authentication	Not assessed	No conclusion
On-orbit behavior	Out of scope	No conclusion

8. Closing FARI Result Card

Field	Result
Conclusion	Inconclusive
Confidence	Low
Required Action	Extend Investigation, then Retest
Priority	Immediate before malformed-input resilience is claimed
Next Decision	Resolve the claim after instrumented execution proves rejection, unsafe effect, or bounded recovery